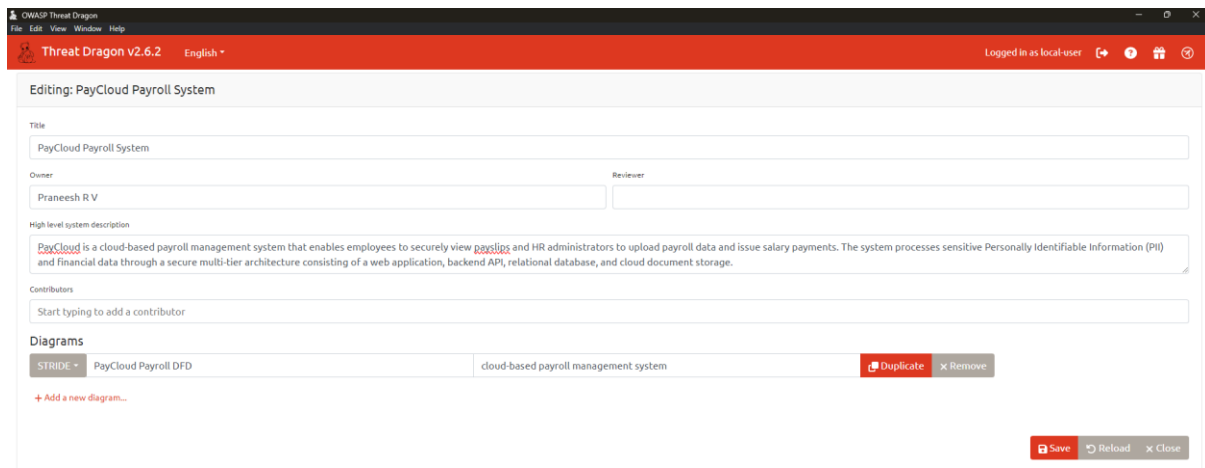


Praneesh R V

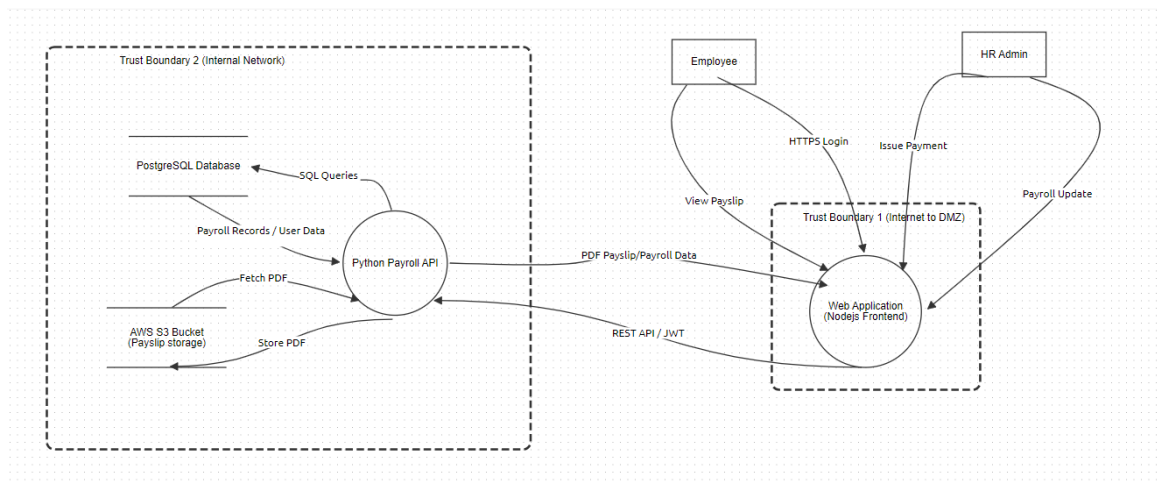
CB.SC.U4CYS23036

SSE Lab Exercise 3 - Threat Modelling with OWASP Threat Dragon

Task 1 - Scope Definition



Task 2 - Architecture Mapping with DFD



Task 3 - STRIDE Threat Identification

Edit Threat #1

Title

User Authentication Spoofing

Type

Spoofing

Status

N/AOpenMitigated

Score

Severity

TBDLowMediumHighCritical

Description

An attacker may use stolen employee or HR administrator credentials to impersonate a legitimate user and gain unauthorized access to the payroll system through the login page.

Mitigations

Implement Multi-Factor Authentication (MFA), enforce strong password policies, use HTTPS, store passwords using salted hashing (bcrypt), and implement account lockout after repeated failed login attempts.

DeleteCancelApply

Threats

New Threat #6

Title

Payroll Data Tampering

Type

Tampering

Status

N/AOpenMitigated

Score

Severity

TBDLowMediumHighCritical

Description

An attacker may modify payroll requests or API messages between the Web Application and Payroll API, resulting in unauthorized salary or payment changes.

Mitigations

Protect communication using HTTPS/TLS, validate JWT tokens, perform server-side input validation, digitally sign sensitive requests, and verify request integrity.

PreviousNextCancelApply

Threats

Edit Threat #8

Title

Payroll Update Repudiation

Type

Repudiation

Status

N/AOpenMitigated

Score

Severity

TBDLowMediumHighCritical

Description

An HR administrator may deny performing payroll updates or issuing payments because there is no reliable audit trail recording user activities.

Mitigations

Maintain secure audit logs with timestamps, record user IDs and IP addresses, protect logs from modification, and regularly review audit records.

DeleteCancelApply

#3 User Authentication Spoofing#8 Payroll Upd

New Threat #9

Title

Sensitive Payroll Information Disclosure

Type

Information disclosure

Status

N/A

Open

Mitigated

Score

Severity

TBD

Low

Medium

High

Critical

Description

Sensitive employee information, salary records, or PDF paystubs stored in PostgreSQL or the S3 bucket may be exposed because of insecure permissions or data leakage.

Mitigations

Encrypt data at rest and in transit, configure least-privilege access controls, secure S3 bucket permissions, encrypt database backups, and mask sensitive information where appropriate.

Previous

Next

Cancel

Apply

A PostgreSQL database in a restricted

Edit Threat #10

Title

Denial of Service Against Web Application

Type

Denial of service

Status

N/A

Open

Mitigated

Score

Severity

TBD

Low

Medium

High

Critical

Description

An attacker floods the Web Application with excessive login or API requests, exhausting server resources and preventing legitimate users from accessing payroll services.

Mitigations

Implement rate limiting, deploy a Web Application Firewall (WAF), enable autoscaling, monitor traffic continuously, and block suspicious IP addresses.

Delete

Cancel

Apply

#2 Denial of Service (DoS) Attacks

Edit Threat #11

Title

Unauthorized Privilege Escalation

Type

Elevation of privilege

Status

N/A

Open

Mitigated

Score

Severity

TBD

Low

Medium

High

Critical

Description

A normal employee exploits weak authorization checks in the Payroll API to access HR administrator functions such as payroll updates or payment processing.

Mitigations

Enforce Role-Based Access Control (RBAC), validate authorization on every API request, apply the principle of least privilege, and perform regular security testing.

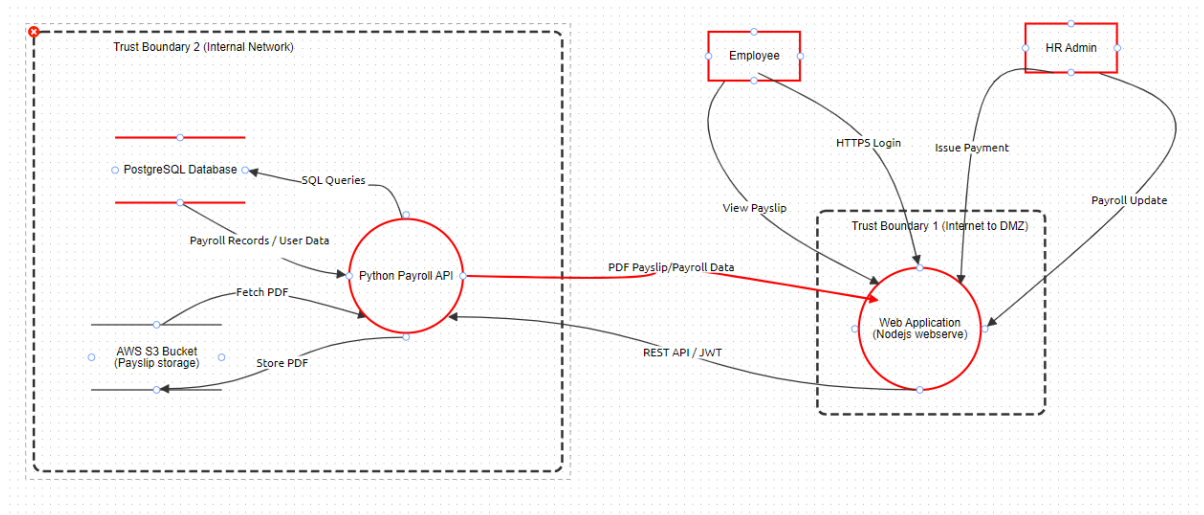
Delete

Cancel

Apply

#6 Payroll Data Tampering

#11 Unauthorized Access



Spoofing

User Authentication Spoofing

An attacker may use stolen employee or HR administrator credentials to impersonate a legitimate user and gain unauthorized access to the payroll system through the login page.

Tampering

Payroll Data Tampering

An attacker may modify payroll requests or API messages between the Web Application and Payroll API, resulting in unauthorized salary or payment changes.

Repudiation

Payroll Update Repudiation

An HR administrator may deny performing payroll updates or issuing payments because there is no reliable audit trail recording user activities.

Information Disclosure

Sensitive Payroll Information Disclosure

Sensitive employee information, salary records, or PDF payslips stored in PostgreSQL or the S3 bucket may be exposed because of insecure permissions or data leakage.

Denial of Service

Denial of Service Against Web Application

An attacker floods the Web Application with excessive login or API requests, exhausting server resources and preventing legitimate users from accessing payroll services.

Elevation of Privilege

Unauthorized Privilege Escalation

A normal employee exploits weak authorization checks in the Payroll API to access HR administrator functions such as payroll updates or payment processing.

Task 4 - Documenting Mitigations

Mitigations

Spoofing - Implement Multi-Factor Authentication (MFA), enforce strong password policies, use HTTPS, store passwords using salted hashing (bcrypt), and implement account lockout after repeated failed login attempts.

Tampering - Protect communication using HTTPS/TLS, validate JWT tokens, perform server-side input validation, digitally sign sensitive requests, and verify request integrity.

Repudiation - Maintain secure audit logs with timestamps, record user IDs and IP addresses, protect logs from modification, and regularly review audit records.

Information Disclosure - Encrypt data at rest and in transit, configure least-privilege access controls, secure S3 bucket permissions, encrypt database backups, and mask sensitive information where appropriate.

Denial of Service - Implement rate limiting, deploy a Web Application Firewall (WAF), enable autoscaling, monitor traffic continuously, and block suspicious IP addresses.

Elevation of Privilege - Enforce Role-Based Access Control (RBAC), validate authorization on every API request, apply the principle of least privilege, and perform regular security testing.